

POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN Y PREVENCIÓN DE FRAUDES

Banco Digital Descentralizado & Exchange | Gerencia de Ciberseguridad y Riesgo Operativo

FICHA TÉCNICA NORMATIVA

Código Documental	POL-SEG-2024-V4
Vigencia	Desde Enero 2024
Supervisión	CISO / Riesgo Operativo
Gerencia Emisora	Ciberseguridad y Riesgo Operativo
Área Ejecutora	SOC / Infraestructura & Billeteras
Jurisdicción	El Salvador (SSF / CSIRT)
Nivel de Seguridad	Uso Interno y Clientes
Aprobación	Comité de Ciberseguridad
Acreditaciones	ISO/IEC 27001:2022 & SOC 2 Type II

Propósito del Documento y Esquema Normativo

Propósito: Establecer los marcos de ciberseguridad, mecanismos de autenticación robusta (KYC/MFA) y motores de inteligencia preventiva para la protección integral de fondos depositados en USD, criptomonedas (BTC, ETH, SOL, BNB) y stablecoins (USDT, USDC). Define controles antibot, gestión de vulnerabilidades y contención de incidentes informáticos para salvaguardar la plataforma bancaria, el Exchange y el token utilitario **OM** de OpenMint S.A. de C.V.

Esquema Estructural: (1) Arquitectura Tecnológica Cero Confianza, (2) Control de Accesos y Verificación KYC/Biométrica, (3) Custodia Fría y Seguridad de Claves Cripto, (4) Motor de Detección de Fraude e Intrusiones, (5) Protección contra Phishing y Suplantación, (6) Protocolo de Respuesta a Incidentes (CSIRT), (7) Canales de Contacto.

1. Arquitectura de Ciberseguridad "Zero Trust" (Cero Confianza)

OpenMint S.A. de C.V. diseña su plataforma híbrida (fiat-cripto) bajo la premisa de verificación continua. Ningún usuario, API, nodo o servidor interno goza de confianza implícita:

- **Microsegmentación de Redes:** El Core Bancario tradicional para la gestión de cuentas corrientes y de ahorro en USD se mantiene completamente separado del motor de coincidencia del Exchange y los nodos de minería/staking.
- **Encriptación End-to-End:** Todas las comunicaciones están protegidas por TLS 1.3 con rotación de claves dinámicas. Las llaves de firmado criptográfico de la entidad están resguardadas en Módulos de Seguridad de Hardware (HSM FIPS 140-3 Nivel 3).

- **Auditoría Continua de Contratos Inteligentes:** Las interacciones con el token propio **OM** y los contratos automáticos de colaterales de préstamos son auditadas semestralmente por firmas independientes de seguridad blockchain.

2. Autenticación Multifactor (MFA) y Protocolos KYC Biométricos

Para mitigar la suplantación de identidad y el apoderamiento de cuentas (*Account Takeover - ATO*), OpenMint establece requisitos de acceso escalonados:

Operación Bancaria / Exchange	Factor 1 (Saber)	Factor 2 (Poseer)	Factor 3 (Ser / Inmutable)
Inicio de Sesión y Consulta USD/Cripto	Contraseña robusta / PIN	Token TOTP (App Authenticator)	Huella Digital / Face ID local
Transferencias ACH / SWIFT en USD	Contraseña de transacción	Código OTP por canal cifrado	Validación pasiva de geolocalización IP
Retiro Cripto (BTC, ETH, SOL, BNB, Stablecoins)	Firma de autorización	YubiKey / WebAuthn o TOTP	Biometría facial 3D en tiempo real (<i>Liveness Test</i>)
Apertura / Desembolso Crédito (Fiat o Cripto)	Firma Electrónica Certificada	Verificación OTP vía SMS/App	Cotejo biométrico contra Documento DUI/Pasaporte

3. Arquitectura de Custodia Criptográfica y Colaterales en Garantía

La seguridad de los activos digitales custodiados por el banco o retenidos como colateral de préstamos cripto (monto máximo \$8,000 USD con retención del 2% al 15%) sigue estándares institucionales:

- **3.1. Billeteras Frías (*Cold Storage* 95%):** El 95% de los activos totales de los clientes (BTC, ETH, SOL, BNB, USDT, USDC y token OM) se resguardan en bóvedas criptográficas desconectadas de internet, distribuidas geográficamente y con esquemas de multifirma (Multi-Sig 3 de 5).
- **3.2. Protecciones en Colaterales PoS/PoW:** Las garantías retenidas que participan en procesos de rendimiento por *Proof of Stake* o minería Bitcoin (*Proof of Work*) operan en nodos validadores aislados. Ante fluctuaciones de mercado o variaciones de tasa (2% al 30%), el contrato automatizado impide cualquier liquidación forzosa en los primeros 6 meses de mora si el cliente mantiene contacto activo y voluntad de reestructuración.

Monitoreo de Llaves Privadas

OpenMint nunca solicita, almacena ni transmite llaves privadas o frases semilla (*seed phrases*) de sus usuarios. Toda integración con billeteras externas para la firma de colaterales se realiza mediante protocolos descentralizados seguros (WalletConnect V2 / HSM Connect).

4. Motor de Inteligencia Anti-Fraude e Intrusiones

El Centro de Operaciones de Ciberseguridad (SOC 24/7) opera un motor probabilístico con aprendizaje automático que evalúa las transacciones en tiempo real:

Tipo de Amenaza	Vector de Ataque Detectado	Acción Automática de Mitigación
Account Takeover (ATO)	Inicio de sesión desde una nueva dirección IP o país atípico combinado con cambio inmediato de credenciales.	Bloqueo preventivo de retiros por 48 horas y notificación por canal alternativo.
Ataque Bot / Brute Force	Más de 5 intentos fallidos de autenticación en menos de 60 segundos desde el mismo segmento IP.	Desafío CAPTCHA avanzado, bloqueo temporal de IP y tasa límite (<i>Rate-Limiting</i>).
Suplantación de Identidad (SIM Swapping)	Cambio reciente de tarjeta SIM detectado a través de APIs de operadores móviles antes de una transferencia.	Suspensión de autorizaciones vía SMS y exigencia de verificación biométrica presencial/app.
Direcciones Cripto Maliciosas	Solicitud de retiro hacia wallets etiquetadas por Chainalysis/Elliptic como estafas o exploit.	Rechazo inmediato de la transacción y congelamiento del ticket de salida.

5. Estrategia de Protección Anti-Phishing y Spoofing

OpenMint implementa estándares globales para evitar que sus clientes sean víctimas de ingeniería social:

- Código Anti-Phishing Personalizado:** Todo correo electrónico oficial enviado por el banco incluye una frase o código secreto configurado previamente por el cliente en su panel de seguridad.
- Políticas DMARC, SPF y DKIM:** Configuración estricta en los dominios corporativos (`openmint.com.sv` y `openmint.bank`) para evitar la falsificación de identidad del correo bancario.
- Monitoreo de Dominios Fraudulentos:** Escaneo automático en tiempo real de registradores web para la detección y congelamiento de sitios web clonados (*typosquatting*).

Regla de Oro Institucional

Ningún ejecutivo, analista o sistema de OpenMint S.A. de C.V. le solicitará jamás su contraseña, código TOTP, clave de transacción o frase semilla por correo electrónico, llamadas telefónicas, WhatsApp o redes sociales.

6. Plan de Respuesta a Incidentes (CSIRT) y Recuperación

En caso de una brecha confirmada, ataque cibernético de denegación de servicio (DDoS) o intento de vulneración de contratos inteligentes, se activa el CSIRT de OpenMint:

- **Contención Inmediata (Fase 1 - 15 minutos):** Aislamiento lógico de los servicios afectados. Si la amenaza compromete la custodia cripto, congelamiento automático de retiros *hot-wallet*.
- **Erradicación y Análisis Forense (Fase 2 - 4 horas):** Análisis de logs en el SIEM, parchado de vulnerabilidades y desinfección de la infraestructura.
- **Notificación Regulatoria (Fase 3 - 12 horas):** Notificación formal a la Superintendencia del Sistema Financiero (SSF) de El Salvador y al Equipo de Respuesta a Incidentes de Ciberseguridad Nacional (CSIRT-SV).
- **Restablecimiento y Seguro de Fondos:** Recuperación de la operativa mediante respaldos fríos y ejecución de la póliza de seguro ciberfinanciero para la restitución inmediata del 100% de los depósitos de los clientes.

7. Canales Oficiales para el Reporte de Incidentes de Seguridad

Si un usuario identifica actividad sospechosa, intentos de phishing o vulnerabilidades en las aplicaciones de OpenMint:

Canal de Atención	Datos de Contacto
Atención de Emergencias 24/7	Centro de Operaciones de Ciberseguridad (SOC)
Correo Reporte de Phishing / Fraude	<code>seguridad@openmint.com.sv</code> / <code>fraud-alert@openmint.bank</code>
Programa Bug Bounty (Vulnerabilidades)	<code>security-disclosure@openmint.bank</code> (Cifrado GPG disponible)
Línea Telefónica Directa	+503 2200-MINT (6468) — Opción 9 (Bloqueo de Emergencia)

OpenMint S.A. de C.V. — Gerencia de Ciberseguridad y Riesgo Operativo. San Salvador, El Salvador. Documento Controlado POL-SEG-2024-V4.